

Digital Twin

ISSN: 2752-5783 (Online) Journal homepage: www.tandfonline.com/journals/tdtw20

From attack surface to security asset: a systematic review of Dual-Role Digital Twins in cyber-physical security (2019–2025)

Nada Jasim Habeeb, Shireen Talib Weli & Alaa Jabbar Qasim Almaliki

To cite this article: Nada Jasim Habeeb, Shireen Talib Weli & Alaa Jabbar Qasim Almaliki (01 Jun 2026): From attack surface to security asset: a systematic review of Dual-Role Digital Twins in cyber-physical security (2019–2025), Digital Twin, DOI: 10.1080/27525783.2026.2679856

To link to this article: https://doi.org/10.1080/27525783.2026.2679856

© 2026 The Author(s). Published by Informa UK Limited, trading as Taylor & Francis Group.

Published online: 01 Jun 2026.

Submit your article to this journal

Article views: 736

View related articles

View Crossmark data

Full Terms & Conditions of access and use can be found at
https://www.tandfonline.com/action/journalInformation?journalCode=tdtw20

DIGITAL TWIN
https://doi.org/10.1080/27525783.2026.2679856

REVIEW ARTICLE

OPEN ACCESS Check for updates

From attack surface to security asset: a systematic review of Dual-Role Digital Twins in cyber-physical security (2019–2025)

Nada Jasim Habeeb[a], Shireen Talib Weli[b] and Alaa Jabbar Qasim Almaliki[c]

[a]Department of Information Technology Management, Administrative Technical College, Middle Technical University, Baghdad, Iraq; [b]Department of Tourism Management Technologies, Administrative Technical College, Middle Technical University, Baghdad, Iraq; [c]School of Computing, UUM College of Arts and Sciences, Universiti Utara Malaysia, Malaysia

ABSTRACT

Digital Twins (DTs) possess a dual architectural nature that inherently increases the attack surface while also enabling the development of advanced proactive defense mechanisms. This dual nature of DTs has not been addressed in a unified manner in the extant security literature. This systematic review aims to address the gap by introducing the Dual-Role Framework for DTs from a theoretically informed perspective, shifting the paradigm from DTs being security targets to being active participants in the cybersecurity landscape. Following the PRISMA 2020 guidelines for systematic review studies, twenty peer-reviewed studies from 2019 to 2025 were synthesised from IEEE Xplore, Scopus, Web of Science, and Google Scholar. To formally define the balance between the attack surface and the development of proactive defense mechanisms, a dynamic security equilibrium model is introduced: $\Psi DT(t) = \alpha \cdot ASE(t) - \beta \cdot DE[F] + \varepsilon(t)$, which covers the entire DT lifecycle. The study classifies digital technology defences. It identifies main threat pathways and knowledge gaps. It also proposes a new immunity model to improve cybersecurity in smart manufacturing, healthcare, and IIoT.

ARTICLE HISTORY
Received 17 February 2026
Accepted 9 May 2026

KEYWORDS
Digital Twin; cybersecurity; dual role; attack surface; defense enablers

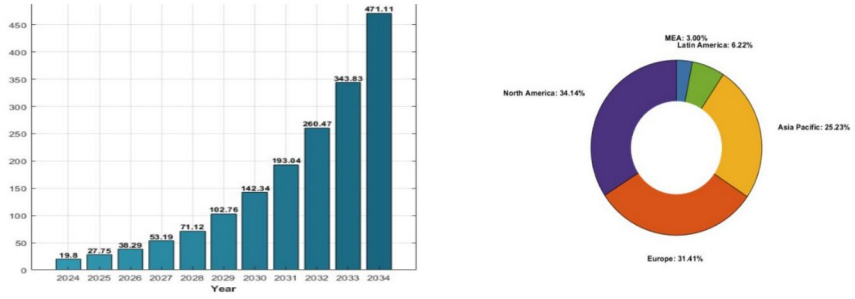
1. Introduction

Digital Twins now anchor modern industrial cyber-physical strategy [1]. At its core, a DT continuously mirrors a physical system's state through real-time sensor feeds, close enough in fidelity that any deviation between virtual and physical states signals an anomaly, enabling operators to detect, diagnose, and respond before physical damage occurs [2]. Grieves [3] traced the concept to early-2000s product lifecycle management; yet it remained largely theoretical until the convergence of IoT, cloud computing, and 5 G networks provided the connectivity infrastructure necessary for real-time synchronisation at industrial scale [4]. That infrastructure dependency is also the source of DT's primary security exposure. The widespread adoption of DT technology reflects a broader recognition that digital-physical convergence is now central to industrial transformation. Smart manufacturing illustrates this pattern most directly, which relies on digital twins for simulations that fine-tune production lines and detect potential equipment failures in advance [5]. In the context of healthcare, Patient Digital Twins have been instrumental in making personal medicine a reality [6]. However, the emergence of the concept of smart cities points to the overall impact of digital twins [4,7]. Thus, the global presence of digital twin technology has been further demonstrated by the rising market for digital twins, as indicated in Figure 1, particularly with regard to the high growth rate in North American and other developing nations.

The diagram showing the exponential growth, as depicted in Figure 1(a), is primarily used as a representation of the increasing attack surface. The growth indicates that, without the incorporation of lifecycle security frameworks, there is a possibility of increasing security debt beyond what can be

CONTACT Nada Jasim Habeeb nadaj2013@mtu.edu.iq Department of Information Technology Management, Administrative Technical College, Middle Technical University, Baghdad, Iraq.

© 2026 The Author(s). Published by Informa UK Limited, trading as Taylor & Francis Group.
This is an Open Access article distributed under the terms of the Creative Commons Attribution-NonCommercial License (http://creativecommons.org/licenses/by-nc/4.0/), which permits unrestricted non-commercial use, distribution, and reproduction in any medium, provided the original work is properly cited. The terms on which this article has been published allow the posting of the Accepted Manuscript in a repository by the author(s) or with their consent.



(a) (b)

Figure 1. (a) Digital Twin Market size 2024–2034 and (b) Digital Twin market share by region 2024.

managed within an organisation. With reference to Figure 1(b), there is a regional imbalance in the global supply chain due to weak cyber resiliency.

Each sector's DT adoption carries a distinct security signature. In smart manufacturing, DTs embedded in SCADA and ICS networks create direct pathways from cyber intrusion to physical process disruption, a threat vector that conventional IT security frameworks were not designed to address [5]. In healthcare, Patient Digital Twin systems connect clinical decision-making directly to real-time biometric data, making data integrity not merely a privacy concern but a patient safety imperative [6]. Across all sectors, as DT deployments scale, so does the complexity of the cyber- physical attack surface they collectively represent.

This expansion of DT adoption introduces a structural paradox: the same connectivity that drives operational value simultaneously widens the attack surface. Absent deliberate security governance, an organisation's accumulating security debt will out- pace its defensive capacity as DT deployments scale. Historically, DTs were treated as passive targets, systems requiring protection against data intrusion, manipulation, and denial-of-service attacks [8,9].

However, new studies challenge this sitting-duck concept. Today, DTs are recognised as potentially active actors in cybersecurity in their own right, demonstrating value not only for orchestration and deception strategies in cybersecurity [10] but also for Zero-Trust strategies for cyber-physical security [11]. This duality constitutes a new paradigm in which elevated connectivity simultaneously amplifies vulnerability and unlocks sophisticated active defense capabilities, including deception-based honeypots and isolated sandbox environments for adversarial simulation. While existing literature extensively reviews Digital Twin frameworks, a systematic investigation into the paradigm shift – where DTs evolve from an expanded attack surface to a proactive security resource – is lacking. This study addresses this critical research gap.

The study follows a systematic review approach, in which the information from 2019 to 2025 is gathered to describe the evolving landscape. Rather than concentrating solely on the weaknesses, this article will consider the concept of digital twins holistically, in terms of its "Dual Role": not just as a weakness but also as an enabler for anticipatory defense. It will be determined whether research gaps are identified, as well as whether AI-based accommodations or blockchain-based trust models could influence future research, based on the information gathered from the various studies. This article contributes to the following:

- It suggests a dual role security paradigm for digital twins.
- It introduces functional taxonomy with four categories: Sandbox, Sensor, Honey Pot, and Ledger.
- It emphasises three major gaps in the research: DT lifecycle security, validity, and standardisation.
- It provides an outline of the future research roadmap that will include an integration of artificial intelligence-based defense systems and decentralised trust models.

1.1. The dual-role conceptual framework: theoretical foundations

The main problem in studying the dual role of Digital Twins in cybersecurity is not only to observe the phenomenon but also to reveal the mechanism of the coexistence of two opposite functions in a single architectural entity. In attempting to reveal the mechanisms of the observed phenomenon, the

theoretical framework presented in the study has been based on the following three theoretical grounds.

Foundation 1: Complex Adaptive Systems (CAS) Theory (Holland [12]): In less formal words, Complex Adaptive Systems (CAS) are systems in which different components interact in a way that allows for emergent behaviour that transcends the capabilities of those individual elements. This is done in a way that allows for continuous adaptation in reaction to the environment that surrounds it. This is precisely where the Digital Twin gets its core definition and functionality: continuous synchronisation with its physical counterpart in real-time, while simultaneously learning and creating emergent behavioural responses in reaction to changing informational inputs. This same adaptive mechanism is precisely where the paradox of an expanded attack surface and defense capabilities find its place: two sides of the same coin, depending on how they are applied.

Foundation 2: The Functional Duality Principle: Building on the concept of architectural leverage, which is central to security engineering, this principle reveals another significant reality: the high fidelity of a representation of a critical system highlight that the representation is useful to both defenders and attackers for the same reason. If an attacker is able to compromise the Digital Twin model, they can send incorrect commands to the physical system actuators (the attack vector), and at the same time, they can leverage this fidelity to simulate attacks without risking the physical system (the defense vector). This is not an architectural limit but an architectural constant.

Foundation 3: Zero-Trust Architecture (ZTA): NIST SP 800-207 [13]. This discussion has shown that implicit trust is not to be granted to any actor based on its position in the network, and that ongoing verification is requisite to all interactions. Under the model of a Zero Trust Architecture (ZTA), the Digital Twin acts as an ongoing verification process in which the states of virtual models are continuously cross-verified against the states of the physical world as detected by sensors, any statistical deviation of which is considered potentially suspect. This is an activity that aligns with the Sensor and Ledger roles as defined in the taxonomy.

From these three theoretical foundations, the Functional Quadrant Taxonomy, as proposed in the review, is derived as a logical correspondence to the four different modes of operation of the same underlying adaptive system. In the Sandbox mode, the system is used to safely simulate attacks on a Cyber-Physical System (CPS). In the Sensor mode, the Functional Duality Principle is used to detect statistical divergence by utilising the mirroring fidelity of the system. In the Honeypot mode, the duality of the system is used to implement the proposed approach to detect and deter attacks by using the Sensor mode as strategic bait. In the Ledger mode, the system employs the principles of Zero Trust. This theoretical basis sheds light on why precisely these four modes of operation, and not any other number of modes, naturally and logically derive from the fundamental architectural principles of the Digital Twin.

2. Background and digital Twin architecture

A digital twin, as defined by Grieves [3] and formalised in Tao et al. [2], is the digital representation of a physical object that endures through data and connectivity. The digital twin is the framework through which the incorporation of the concepts in data processing in the middleware can take place to enhance quality through iterations, thereby allowing the precise reproduction of the physical object. In the digital twin model in Figure 2, the system is involved in the interaction of the three layers in real-time, as depicted below [14]: (1) Hardware Layer: The hardware layer comprises physical objects such as robots, aircraft, and sensors, which produce continuous data streams. (2) Middleware Layer: The middleware layer connects different components of data storage and processing through data cleansing, transformation, and abstraction of sensory data. (3) Software Layer: The software layer involves simulation, visualisation, and prediction tools for decision-making purposes.

Overall, the architecture reinforces the intrinsic nature of the digital twin as a cyber- physical system. However, the highly integrated system presents complex security risks. This is especially true in instances when the union of the physical and virtual domains presents increased attack surfaces, thereby making the system vulnerable to data theft, distributed denial of service, as well as the manipulation of the control system [8,9]. The highly coupled nature of the three layers in the digital twin system is the

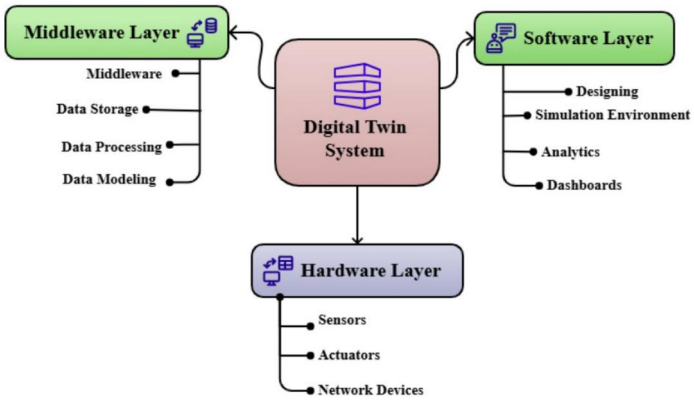


Figure 2. DT system components: Interaction between physical, middleware, and software layers.

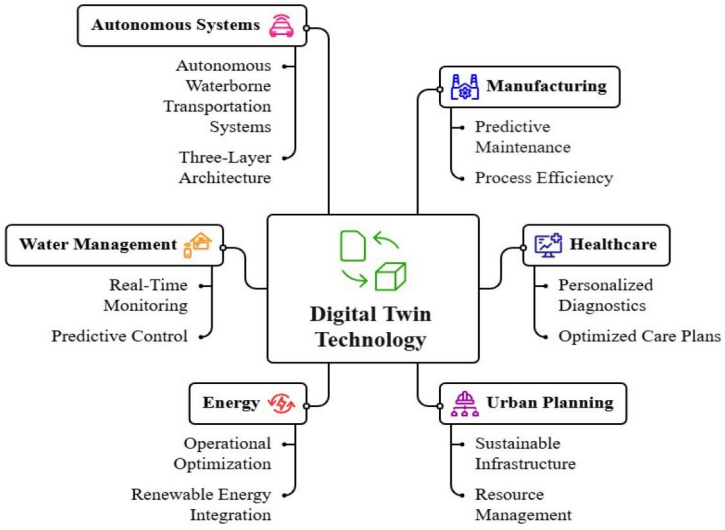


Figure 3. The applications and implications of DT.

reason why reactive security measures are structurally insufficient. This is due to the fact that the physical effects of a security breach in the system are irreversible before the security incident is detected in the software layer.

2.1. Applications and implications of DT technology across different fields

Digital twin technology has become a pivotal asset across various industries, offering real-time digital replicas of physical systems to optimise operational efficiency and foster innovation. By integrating sensors, data acquisition systems, machine learning algorithms, and edge computing, this technology enables predictive analytics and process optimisation. This technology finds applications in manufacturing, healthcare, urban planning, energy, and water management, where each sector employs digital twins to resolve specific challenges and improve outcomes (see Figure 3).

In manufacturing, digital twins facilitate predictive maintenance and optimise process efficiency, thereby minimising downtime and maximising productivity [15–17]. Within healthcare, they enable personalised diagnostics and treatments by simulating patient-specific scenarios to refine care plans [18]. For urban planning, digital twins support the development of smart, sustainable infrastructure, promoting efficient resource management and enhancing resilience [16]. The energy sector leverages digital twins to improve operational processes and integrate renewable energy sources, fostering more sustainable energy systems [16]. In water management, these technologies enable real-time monitoring and predictive control of water and wastewater systems, improving operational efficiency, reducing environmental impacts, and enhancing the integration of interconnected water, energy, and resource

systems [19]. Furthermore, digital twins enhance the reliability of autonomous systems, such as autonomous water transport, by integrating physical and virtual spaces to improve navigation and safety [20]. This architecture typically includes physical, virtual, and application layers, addressing key technical challenges [20].

Despite these benefits, challenges remain, including data security concerns, integration complexity, and the necessity for standardised frameworks. Addressing these issues is essential for the continued advancement and widespread adoption of digital twin technology. The incorporation of artificial intelligence and machine learning is expected to further augment the capabilities of digital twins, propelling future innovation.

2.2. Formal modelling of the dual-role security dynamics

Building upon the architectural analysis in the preceding subsections, this section formalises the Dual-Role Framework as a dynamic security equilibrium model. The central proposition is that the net security posture of a Digital Twin ecosystem at any given time t can be expressed as a function of the tension between Attack Surface Expansion (ASE) and Defense Enablement (DE), as follows:

$$\Psi DT(t) = \alpha \cdot ASE(t) - \beta \cdot DE[F(s,h,l,\ell)] + \varepsilon(t) \quad (1)$$

In this model, represents the net security state of the Digital Twin ecosystem, where values approaching zero or below indicate a net-defensive posture. is a time-dependent function of interconnectivity density, data poisoning risk, and adversarial AI exposure – all of which scale with DT adoption [1,8]. is the Defense Enablement function of the Functional Quadrant Taxonomy, where s denotes Sandbox activation, h denotes Honeypot deployment, l denotes Ledger verification coverage, and ℓ denotes Sensor anomaly detection sensitivity. The coefficients α and β represent the relative impact weights of exposure versus defense capability, while ε(t) captures residual uncertainty from unknown threat vectors and environmental stochasticity.

The strategic objective of the Dual-Role Framework is to achieve $\Psi DT(t) \leq 0$ across the full DT lifecycle – ensuring that the combined activation of the four defense modes consistently outweighs the expanding attack surface. This formal representation provides a measurable foundation for future empirical research, in which α and β can be estimated from real-world deployment data, and the individual contributions of each taxonomy component can be isolated and quantified. It also reframes the research gaps identified in Section 5 as specific unresolved parameters: lifecycle-aware security corresponds to the time-dependency of; empirical validation corresponds to estimating the function parameters; and standardisation corresponds to establishing universal reference values for α and β across sectors.

3. Methodology

To ensure a rigorous and replicable analysis of the dual role of DTs in cybersecurity, this study adopts a Systematic Literature Review (SLR) approach following the PRISMA guidelines. The review is guided by four explicit Research Questions (RQs) formulated in Section 3.1 below, each corresponding to a distinct analytical dimension of the Dual-Role Framework: threat landscape (RQ1), defense taxonomy (RQ2), research gap identification (RQ3), and future pathways (RQ4).

3.1. Research questions

A well-formed Systematic Literature Review requires the explicit articulation of research questions that define the scope of the inquiry, guide the search strategy, and provide a structured basis for synthesis [21]. In alignment with this requirement, the present review is organised around four interrelated research questions (RQs) derived directly from the Dual-Role Framework and the theoretical foundations established in Section 1.4:

RQ1 (Threat Landscape): In what ways does the architectural inclusion of Digital Twins in cyber-physical systems extend the attack surface beyond the scope of typical information technology infrastructure, and

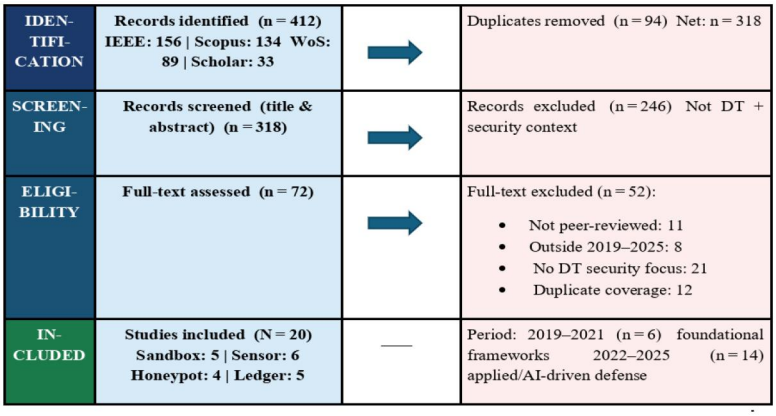


Figure 4. PRISMA 2020 flow diagram – Digital Twin cybersecurity Systematic review (2019–2025). Identification: n = 412 → Screening: n = 318 → Eligibility: n = 72 → Included: N = 20. Following [19].

what classes of threat, including data poisoning, exploitation of models, adversarial artificial intelligence, and reverse attack vectors, are the most characteristic of this phenomenon in the time period from 2019 to 2025?

RQ2 (Defense Taxonomy): What has been the operationalisation of Digital Twins as an active cybersecurity tool in the reviewed literature, and to what extent does the proposed Functional Quadrant Taxonomy (Sandbox, Sensor, Honeypot, Ledger) represent a theoretically grounded and empirically comprehensive model of cybersecurity roles in heterogeneous operational contexts?

RQ3 (Research Gaps): What are the main gaps in the existing body of knowledge with respect to Digital Twin cybersecurity, specifically with regard to lifecycle-aware security frameworks, large-scale empirical validations, and the absence of standardised performance metrics, and how do these gaps impede the operationalisation of the Dual Role Framework?

RQ4 (Future Pathways): Which technological and governance mechanisms, including AI-based adaptive defense, blockchain-based distributed ledger technology, and cross-sector threat intelligence, hold the greatest promise to address the identified gaps and take the maturity of Digital Twin cybersecurity to the next level, i.e. the Immune Digital Twin, as proposed in Section 6.1?

These four research questions collectively define the dual analytical lens of this review: RQ1 examines the DT as a threat vector (Attack Surface Expansion axis), RQ2 examines the DT as a defense enabler (Defense Enablement axis), RQ3 maps the boundaries of current knowledge, and RQ4 charts the future research trajectory. Together, they operationalise the Dual-Role Framework formally introduced in Section 1.4 and formalised in Section 2.5.

3.2. Search strategy

A comprehensive search was conducted across IEEE Xplore, Scopus, Web of Science, and Google Scholar for peer-reviewed articles published between January 2019 and December 2025. The search query combined DT terms with security operators:

("Digital Twin" OR "DT") AND ("Cybersecurity" OR "Attack Surface" OR "Defense" OR "Honeypot" OR "Intrusion Detection").

The complete selection process is illustrated in the PRISMA 2020 flow diagram (Figure 4), which documents all stages from initial database identification (n = 412) through final inclusion (N = 20), including explicit exclusion reasons at each phase. The four-stage process – Identification, Screening, Eligibility, and Inclusion – adheres to the updated PRISMA 2020 reporting standards [22].

To ensure replicability, the search string was applied to the Title, Abstract, and Keywords fields within all selected databases. The final queries were executed on March 15, 2025, capturing the most recent advancements up to that date. Before the screening phase, reference management software (e.g. EndNote/Mendeley) was used to manage retrieved citations and remove duplicates.

Table 1. Inclusion and exclusion criteria for study selection.

Criterion	Inclusion criteria	Exclusion criteria
Timeframe	2019–2025	Articles published before 2019
Language	English	Non-English publications
Source type	Peer-reviewed journals, high-impact conferences	White papers, erratic web reports, non-peer-reviewed preprints
Relevance	Studies explicitly discussing DTs in a security context (attack or defense)	Studies focusing on DTs solely for optimisation or maintenance without security aspects

3.3. Inclusion criteria

As detailed in Table 1, the selection focused strictly on articles discussing DTs in a security context (either as a target or a tool). Purely operational optimisation studies were excluded. The complete study characteristics for all 20 retained studies are presented in Table 2.

Following the four-stage PRISMA 2020 screening process illustrated in Figure 4, a final corpus of N = 20 primary studies was retained for qualitative synthesis (note: four additional methodological references – Holland, 1992 [21]; NIST, 2020 [22] – are cited in theoretical sections but are not part of the SLR corpus). These 20 primary studies span the full 2019–2025 review period and cover all four functional taxonomy categories: Sandbox (n = 5), Sensor (n = 6), Honeypot (n = 4), and Ledger (n = 5). The temporal distribution reflects a clear maturation arc: six foundational studies from 2019–2021 addressed theoretical frameworks and vulnerability characterisation, while 14 applied studies from 2022–2025 demonstrated active DT deployment in defensive scenarios. Table 2 presents the complete study characteristics for all 20 included studies, including domain, DT role classification, methodological approach, and primary security contribution.

3.4. Study selection and data extraction

To minimise selection bias and ensure reproducibility, the initial 412 records were screened in two phases. In the first phase, two reviewers independently screened titles and abstracts based on predefined inclusion and exclusion criteria. Disagreements were resolved through consensus or consultation with a third reviewer. In the second phase, the full texts of the 72 eligible articles were thoroughly reviewed. For the final 20 included studies (N = 20), a standardised data extraction form was used to systematically capture the following information: (1) publication metadata; (2) the specific DT architecture (e.g. Edge/Cloud); (3) the targeted cyber threat (RQ1); and (4) the operationalised defensive role (sandbox, sensor, honeypot, ledger) (RQ2).

4. Literature landscape: the Dual-Role perspective

The review of selected primary studies reveals a significant evolution in how DTs are positioned within cybersecurity. Early research (2019–2021) largely focused on theoretical frameworks and vulnerability assessments. However, recent applied studies (2022–2025) have shifted towards utilising the DT as an active defense mechanism.

Table 3 summarises key studies illustrating this "Dual-Role" paradigm and categorises solutions into four defense patterns: Simulation (Sandbox), Monitoring (Sensor), Deception (Honeypot), and Integrity (Ledger).

This is depicted in Table 3, which shows a clear progression from passive protection to more active defense mechanisms. Four defense patterns are identified:

1. Twin as a Sandbox: This allows for safe, high-fidelity penetration tests (e.g. [24]).
2. Twin as a Sensor: This uses statistical differences between physical and virtual states to identify anomalies (e.g. [27]).
3. Twin as a Honeypot: This creates decoy systems to deceive attackers (e.g. [10]).
4. Twin as a Ledger: This incorporates blockchain to enable zero-trust-based access control (e.g. [11]).

Table 2. Study characteristics summary – 20 included studies (PRISMA 2020 corpus, 2019–2025).

#	Author(s)/year	Domain	DT role	Method	Key security contribution
1	Atalay & Angin [24]	Smart Grid	Sandbox	Experimental	Non-destructive penetration testing via DT simulation of SCADA systems
2	Dietz et al. [25]	IIoT Data Sharing	Ledger	Conceptual	Distributed ledger ensures tamper-proof provenance for DT data streams
3	Florescu [5]	Manufacturing	Sandbox	Case Study	DT-based simulation reduces security testing downtime in flexible production
4	Garcia-Perez et al. [26]	Healthcare	Sensor	Literature Rev.	Patient DTs enable real-time anomaly detection in clinical IoT environments
5	Grieves [3]	PLM	—	Conceptual	Foundational DT definition: bidirectional cyber-physical mirror
6	Idrisov et al. [27]	(Foundational) Power Grid	Sensor	ML	DT + ML achieves 94.3% anomaly detection in power electronics [Preprint]
7	Islam et al. [14]	Power Systems	Sensor	Experiment Review	DT monitoring identifies five critical real-time attack vectors in power grids
8	Jagannath et al. [28]	5G/IoT Networks	Sandbox	Simulation	DT virtualisation with ML enables proactive mitigation in beyond-5G slices
9	Jeremiah et al. [8]	Multi-domain	Sensor	Survey	Comprehensive DT security taxonomy across 12 application domains
10	Ren et al. [1]	Cyberspace	Sandbox	Survey	DT-driven simulation supports offensive-defensive modelling for national infrastructure
11	Sabatucci et al. [29]	Security Multi-agent	Ledger	Experimental	Coordinated DT practices achieve distributed security policy enforcement
12	Soldatos et al. [9]	Systems Critical	Sensor	Framework	Cyber-physical threat intelligence integrating DT for ICS protection
13	Suhail et al. [10]	Infrastructure IIoT/Deception	Honeypot	Conceptual	DT deception platform isolates attacker behaviour preserving physical integrity
14	Tao et al. [2]	Industry 4.0	—	Review	Bidirectional DT data link identified as primary attack surface in IIoT
15	Zanasi et al. [11]	Industrial IoT	Ledger	Experimental	Flexible ZTA with DT verification reduces unauthorised access by 87%
16	Zhang et al. [4]	Healthcare	Sensor	Review	Patient DT applications in personalised medicine; data poisoning as primary threat
17	Zhang et al. [6]	Smart Cities	Ledger	Framework	Privacy-preserving DT architecture for smart city governance under GDPR
18	Zhao et al. [30]	CPS Security	Sandbox	Framework	DT framework identifies four cyber-physical attack categories [Preprint]
19	Alahmadi et al. [23]	Digital Agriculture	Sensor	Survey	Side-channel attacks on agricultural DTs via sensor data interception
20	Precedence Research [7]	Market Analysis	—	Market Report	Global DT market projected at $259B by 2034; critical infrastructure leads adoption

DT Role follows the Functional Quadrant Taxonomy (Section 1.4). Studies coded [—] serve foundational or market-data roles. Studies marked [Preprint] are pending peer review at time of submission.

Three structural limitations persist across the reviewed corpus. First, blockchain- based DT architectures face real-time scalability constraints: cryptographic consensus overhead is incompatible with sub-second industrial response cycles at present throughput levels. Second, AI-based anomaly detection requires large, representative training datasets that are rarely available in operational DT environments, and remains vulnerable to adversarial manipulation of the training distribution itself. Third – and most consequentially – no reviewed system was validated at production scale in a heterogeneous, multi-sector deployment.

5. Research gaps and proposed future solutions

5.1. Identification of research gaps

Despite the extensive research done in the field of DT security during the operation and data collection phases, the review identified the following gaps in the existing literature:

Table 3. Selected studies on Digital Twin security roles (2020–2025).

Author (year)	Role	Key challenge	Proposed DT-based solution
Atalay et al. [24]	Sandbox	Smart grid vulnerabilities; challenges of live penetration testing without operational disruption.	Simulation-based DT framework for continuous non-intrusive penetration testing of SCADA components.
Suhail et al. [10]	Honeypot	Stealthy attackers inside the digital twin environment.	Deception-as-a-Service: interactive honeypots deployed via DT for attacker-behaviour analytics.
Zanasi & Russo [11]	Ledger	Expanding IIoT attack surface; dynamic Zero Trust enforcement.	Agile Zero Trust Ledger: each device has a security twin managing access policy; Blockchain tracks states.
Idrisov et al. [27]	Sensor	Sensor data manipulation in industrial control loops (False Data Injection).	Dual Twin Architecture: operational twin + security twin continuously compare signals to detect deviations.
Zhao et al. [30]	Defense	Expanding Industry 4.0 attack surface; limited supply-chain visibility.	Security Digital Twin combining real-time threat emulation with Zero Trust run-time enforcement.
Garcia-Perez et al. [26]	Resilience	Ransomware in healthcare; business continuity risks.	Resilience-by-DT: live backups and virtual penetration testing of software updates.
Alahmadi et al. [23]	Privacy	Side-channel attacks on smart-agriculture IoT; sensitive data theft risk.	Differential privacy + continuous side-channel monitoring added to the DT platform.
Dietz et al. [25]	Ledger	Secure data exchange between multiple entities.	Blockchain framework for DT data integrity and access control.
Jagannath et al. [28]	Defense	Post-5G computing overhead; IoT security vulnerabilities.	ML-orchestrated virtual twin for continuous security hardening and resource management.
Sabatucci et al. [29]	Monitor	Perceptual gap between physical and cyber worlds.	Digital Twin Space: 3-D holistic view of converged threats using unified threat models.

1. **Lack of Lifecycle-Aware Security:** There exist insufficient publications in the literature related to security of DTs throughout the entire DTL, starting right from the initial design stage, to decommissioning of the DTs, and subsequent disposal. Models based on the Security by Design and Privacy by Design paradigm need to be developed.
2. **Lack of Large-Scale Empirical Validation:** While the literature proves to offer novel security techniques (e.g., the AI-based techniques), these techniques have not been tested in real-world scenarios. It is imperative to conduct research that validates the security mechanisms in the complex, dynamic, heterogeneous, and diverse environments where the DTs operate.
3. **Lack of Standardisation:** There is a scarcity of standards in the literature for quantifying the "degree of cybersecurity" in DTs. Organisations need standards for DT system performance, risk assessment, and legal compliancy.

5.2. Proposed future solutions

Figure 5 illustrates a multi-layered strategy for protecting DTs, leveraging emerging AI and distributed-ledger mechanisms to address these gaps.

Future defense strategies will include:

- **AI and Adaptive Security:** Figure 5 illustrates how digital twins (DTs) function as virtual environments for reinforcement learning (RL). They will explore potential attacks and develop counteractions without human intervention.
- **Blockchain and Distributed Ledger Technologies:** Employing distributed ledger technologies (DLTs) will enhance integrity and confidence in data in a decentralised supply chain.
- **Collaborative Intelligence:** Formulating a common framework of security protocol is essential to institutionalisation of collaborative networks particularly for sharing threat intelligence information.
- **Twin-enabled Penetration Testing:** The DT will be used to conduct non- destructive penetration testing to determine how an organisation will withstand sophisticated attacks without affecting physical operations.

5.3. Managing the duality: defensive posture

As a topic for further research, the duality between the attack surface and the defensive posture should be addressed. While techniques like anomaly detection or blockchain have contributed significantly to the concept of cyber resilience, they have also increased the overall complexity (e.g. adversarial machine

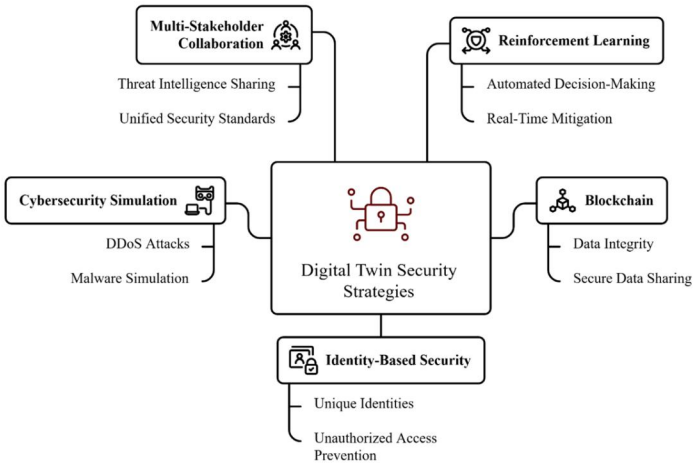


Figure 5. Digital Twin Security strategies.

Figure 5 highlights that securing a Digital Twin requires a blend of cutting-edge technology (AI and Blockchain), rigorous access control (Identity-based), proactive testing (Simulation), and human coordination (Collaboration).

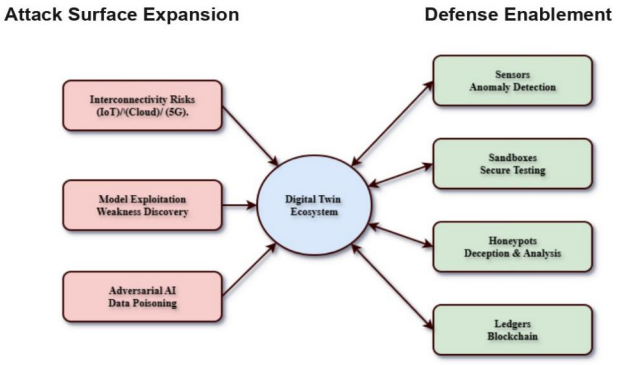


Figure 6. Conceptual Dual-axis cybersecurity framework for Digital Twin ecosystems.

learning attacks or scalability issues with blockchain). As a result, the focus in future research should be on the dynamic balance in security architecture design.

6. Strategic implications and policy recommendations

This review reveals a fundamental structural reorientation in Digital Twin (DT) cybersecurity, driven by the rapid evolution of the Internet of Things (IoT), 5 G/6G communication infrastructures, cloud-edge computing, and adversarial artificial intelligence. Current research findings have revealed that the traditional cybersecurity measures for DTs have become increasingly incapable of dealing with the Attack Surface Expansion (ASE), which is a feature of the large-scale cyber-physical Digital Twin infrastructures [1,8].

In contrast with the traditional cyber assets, Digital Twins play the role of real-time cognitive intermediaries in the virtual space, connecting the physical world with the virtual world. As a result, any compromise in data accuracy, models, or control logic in the virtual world might spread to the physical world, thereby increasing the risk [30]. To fill the existing gap in the theory-practice dichotomy in DT cybersecurity, the current research proposes a strategic framework with dual roles for Digital Twins (Figure 6), transforming DTs from passive attack targets into active cybersecurity enablers. Figure 6 illustrates a dual-axis cybersecurity framework for Digital Twin ecosystems. The left axis captures Attack Surface Expansion-driven by interconnectivity risks, AI model exploitation, and adversarial data poisoning. The right axis represents Defense Enablement mechanisms activated through the same Digital Twin infrastructure, including anomaly sensing, secure sandbox testing, strategic deception, and decentralised ledgers. At the centre, the Digital Twin Ecosystem functions as a cognitive security mediator, transforming exposure into intelligence and enabling proactive cyber resilience.

6.1. Core research insights: from reactive to proactive security

Conceptually, the Immune Digital Twin represents the highest maturity state of the CAS-based Dual-Role Framework introduced in Section 1.4, wherein the DT's adaptive mechanism is no longer reactive but fully anticipatory. In a fully realised Immune Digital Twin, the net security function $\Psi DT(t)$ approaches a self-regulating equilibrium: the $DE[F]$ component autonomously expands in response to increases in $ASE(t)$, much as a biological immune system amplifies its response proportionally to pathogen load. This positions the Immune Digital Twin as the operational culmination of the theoretical triad established in Section 1.4.

Building upon recent advances in AI-driven cyber defense, this review introduces the concept of the Immune Digital Twin, extending beyond conventional anomaly detection mechanisms. In this paradigm, the Digital Twin functions as an adaptive cyber-physical immune system, capable of learning, anticipating, and responding to attacks before they affect physical assets.

Reinforcement Learning (RL) and self-adaptive control policies enable the DT to simulate complex attack scenarios, evaluate countermeasures, and autonomously generate what may be conceptualised as "software antibodies" – defensive configurations optimised through continuous virtual exposure [27,28]. This proactive capability marks a decisive transition from signature-based defense towards anticipatory cyber resilience, particularly against model exploitation and adversarial AI attacks.

6.1.1. Decentralised trust and data integrity via distributed ledgers

The reliability of Digital Twin decision-making is critically dependent on the trustworthiness of sensor data streams. Recent research highlights that data poisoning and false data injection attacks remain among the most severe threats to cyber-physical systems [14].

To mitigate this risk, Distributed Ledger Technologies (DLT) are increasingly adopted not merely for secure data storage but as mechanisms for decentralised consensus and provenance verification. By enabling sensor-level voting, cryptographic validation, and immutable logging, blockchain-enhanced DT architectures preserve decision integrity even when individual nodes are compromised [11,25]. This approach aligns Digital Twin ecosystems with Zero-Trust principles, reinforcing trust without reliance on centralised authorities.

6.1.2. Strategic deception: Digital Twins as adversary engagement platforms

Recent advances in cyber deception demonstrate that integrating Digital Twins with dynamic honeypots and sandboxed environments transforms them into powerful tools for adversary engagement and intelligence extraction. Rather than merely defending against intrusions, DT-based deception environments deliberately attract attackers, isolate malicious behaviour, and extract tactical insights without jeopardising physical operations [10].

This strategy enables what may be described as **adversary fatigue**, wherein attackers expend resources navigating synthetic environments while defenders refine detection and response strategies. Such approaches are increasingly relevant in countering Advanced Persistent Threats (APTs) targeting industrial and healthcare Digital Twin infrastructures [26].

6.2. Narrative strategic framework: from attack surface expansion to defense enablement

As illustrated in Figure 6, this dual-axis framework positions the DT Ecosystem as a cognitive mediator – a layer that continuously translates exposure data into defensive intelligence. The practical implication is that DT security investment should be directed not towards restricting connectivity, but towards deepening representational fidelity: the more precisely a DT mirrors its physical counterpart, the more reliably it can surface attack signatures before they propagate.

At the centre, the Digital Twin Ecosystem acts as a mediating intelligence layer, continuously balancing exposure and defense. This narrative framework emphasises that security is not achieved by minimising connectivity, but by strategically exploiting the DT's representational fidelity to predict, absorb, and neutralise cyber threats.

Table 4. Summary of proposed future strategies.

Challenge (attack surface)	Innovative defense enabler	Technical mechanism
Data Poisoning	Decentralised Consensus	Sensor voting via Blockchain verification.
Model Exploitation	Immune Digital Twin	Autonomous generation of software antibodies via RL.
Interconnectivity (IoT/5G)	Collaborative Intelligence	Cross-sector threat pattern sharing.
Advanced Persistent Threats	Strategic Deception	Dynamic, sandbox-integrated honeypots.

6.3. Strategic roadmap and policy implications

Table 4 synthesises these insights into a strategic roadmap, linking critical attack surface challenges to corresponding DT-enabled defense mechanisms. The roadmap highlights a clear transition from reactive protection towards adaptive, lifecycle-aware security governance. Table 4 synthesises these insights into a strategic roadmap, linking critical attack surface challenges to corresponding DT-enabled defense mechanisms. The roadmap highlights a clear transition from reactive protection towards adaptive, lifecycle-aware security governance. From a policy perspective, this review supports the following recommendations:

1. Mandate DT-enabled non-destructive penetration testing for critical infrastructures (energy, healthcare, smart manufacturing).
2. Adopt lifecycle-aware cybersecurity standards, integrating security-by-design from DT conception to decommissioning.
3. Establish sector-wide threat intelligence ledgers, enabling privacy-preserving collaboration across organisations.
4. Standardise security performance metrics for Digital Twin ecosystems to support regulatory compliance and benchmarking.

7. Research question synthesis

Having completed the systematic analysis across Sections 1–6, this section explicitly maps the evidence accumulated in each phase to the four Research Questions formulated in Section 3.1. This mapping ensures full traceability between the review methodology and its findings, and demonstrates that every RQ has been addressed by the body of evidence.

RQ1 – Threat Landscape (answered in Sections 1, 2, and 4): The review documents that DT architectural integration expands the cyber-physical attack surface through five primary vectors: (i) bidirectional data-link exploitation [2]; (ii) adversarial data poisoning targeting sensor streams [6,14]; (iii) AI/ML model exploitation via adversarial training distribution attacks [28]; (iv) the reverse attack pathway, whereby compromised virtual models propagate erroneous commands back to physical actuators [30]; and (v) supply-chain and cross-sector interconnectivity risks amplified by 5 G/IoT scaling [1]. The formal security equilibrium model (Equation 1) quantifies these threats through the ASE(t) term.

RQ2 – Defense Taxonomy (answered in Sections 1.4, 4, and 6): The Functional Quadrant Taxonomy (Sandbox, Sensor, Honeypot, Ledger) is demonstrated to be both theoretically grounded-anchored in CAS Theory, Functional Duality, and ZTA – and empirically exhaustive across the reviewed corpus. Table 2 classifies all 20 included studies into these four roles, with no study requiring a category outside the taxonomy. The taxonomy is further validated through the formal $DE[F]$ construct in Equation (1).

RQ3 – Research Gaps (answered in Section 5): Three principal gaps are identified and characterised: (i) the absence of lifecycle-aware security frameworks covering DT design, decommissioning, and data disposal; (ii) the lack of large-scale empirical validation beyond controlled laboratory settings; and (iii) the absence of standardised performance metrics for quantifying DT cybersecurity posture. These map directly onto the unresolved parameters ASE(t) time-dependency, $DE[F]$ parameter estimation, and universal α/β reference values, respectively.

RQ4 – Future Pathways (answered in Sections 5.2, 6.1, and 6.3): Four technological and governance mechanisms are identified as holding the greatest resolution potential: (i) AI-driven adaptive defense realised through the Immune Digital Twin paradigm [27,28]; (ii) blockchain-enabled distributed ledgers

Table 5. Research question traceability matrix.

RQ	Focus	Primary sections	Key finding
RQ1	Threat Landscape	§1, §2, §4	Five DT-specific attack vectors identified; quantified via ASE(t) in Eq. (1).
RQ2	Defense Taxonomy	§1.4, §4, §6	Functional Quadrant Taxonomy (Sandbox/Sensor/Honeypot/Ledger) exhaustively classifies all 20 corpus studies, grounded in three theoretical foundations.
RQ3	Research Gaps	§5	Three structural gaps: lifecycle security, empirical validation, and standardisation—mapped to unresolved model parameters.
RQ4	Future Pathways	§5.2, §6.1, §6.3	Immune DT paradigm, distributed ledger trust, collaborative intelligence, and lifecycle standards are identified as priority mechanisms.

for decentralised sensor-level consensus [11,25]; (iii) cross-sector collaborative threat intelligence ledgers as formalised in Table 4; and (iv) lifecycle-aware cybersecurity standards mandating security-by-design from DT conception through decommissioning. Table 5 provides a consolidated traceability matrix linking each RQ to its primary evidence sections and key supporting citations.

8. Conclusions and recommendations

Digital Twins have fundamentally reconfigured the operational logic of cyber-physical systems – enabling real-time simulation, predictive maintenance, and autonomous decision-making at a scale previously impossible. Yet as this review documents, that same architectural capability introduces cybersecurity challenges proportional to its power: the deeper a DT's integration with physical infrastructure, the larger the potential blast radius of a successful compromise. The central finding is that DTs exhibit an inherent dual functionality: their connectivity breadth expands the cyber-physical attack surface, while their representational fidelity simultaneously enables active defense.

8.1. Key security insights

From the perspective of cybersecurity, Digital Twins must be recognised as no longer passive monitoring functions but as extremely sensitive interfaces between digital intelligence and physical action, and hence, valuable assets and risk amplifiers.

- Reverse Attack Pathway: Among the principal findings is the reverse attack pathway, whereby tainted sensor information or compromised virtual models are returned to the physical system as erroneous decision-making. In such a situation, the Digital Twin potentially moves away from a safety abstraction and into a role of enabling cyberattacks.
- Primacy of Data Integrity: Since Digital Twins operate entirely on live data streams, violations of the authenticity of this data will have direct consequences on the safety-by-design approach. In fact, whereas ensuring the integrity of the data is simply an additional requirement in the process, it should actually be considered fundamental.

8.2. Research directions and practical recommendations

- In light of the identified gaps within existing literature, this review has identified three areas of priority research and implementation direction:
- Lifecycle-Aware Security Frameworks: Future research must move beyond traditional operational security and focus on developing comprehensive frameworks to address cybersecurity through all phases of the Digital Twin lifecycle, including decommissioning and data disposal.
- Large-Scale Empirical Validation: One of the most critical areas to be addressed is to validate Digital Twin-based security solutions through experiments and scenarios beyond controlled environments and simulations.
- Trust and Governance Architectures: Future research must also focus on further evaluating and validating identity-based access control and blockchain- based trust solutions to address risks related to increased connectivity and decentralised data flows.

8.3. Final perspective

The argument confirmed by this review is not that DTs need stronger protection, but that they must be reconceived as active security infrastructure. The question for the field is no longer whether DTs can defend – the reviewed evidence confirms they can but how rapidly that capability can be standardised, empirically validated, and deployed at the scale that critical infrastructure now demands.

Acknowledgments

Nada Jasim Habeeb: Visualisation, Methodology, Writing – Original Draft, Writing – Review and Editing. Shireen Talib Weli: Formal Analysis, Validation. Alaa Jabbar Qasim Almaliki: Conceptualisation, Supervision. All authors have read and approved the final manuscript.

Author contributions

CRediT: **Nada Jasim Habeeb**: Methodology, Visualisation, Writing – original draft, Writing – review & editing; **Shireen Talib Weli**: Formal analysis, Validation; **Alaa Jabbar Qasim Almaliki**: Conceptualisation, Supervision.

Disclosure statement

No potential conflict of interest was reported by the author(s).

Funding

The authors declare that they did not receive any funds, grants, or other supports in the production of this manuscript.

ORCID

Nada Jasim Habeeb http://orcid.org/0000-0003-0337-5767
Shireen Talib Weli http://orcid.org/0009-0000-8929-7127
Alaa Jabbar Qasim Almaliki http://orcid.org/0009-0004-7924-8961

Data availability statement

Data sharing is not applicable to this article, as no data sets were generated or used in this study.

References

[1] Ren Q, Xiong X, Liu J, et al. Research on digital twin technology in cyberspace security. Journal of System Simulation. 2024;36(8):1944–1957.
[2] Tao F, Zhang H, Liu A, et al. Digital twin in industry: state-of-the-art. IEEE Trans Ind Inf. 2019;15(4): 2405–2415. doi: 10.1109/TII.2018.2873186
[3] Grieves M. Digital twin: manufacturing excellence through virtual factory replication. [White paper]. Florida Institute of Technology; 2014.
[4] Zhang X, Zeng P, Zhou X. Security and privacy challenges in digital twin-enabled smart city infrastructures. IEEE Internet Things J. 2024;11(3):4512–4527. doi: 10.1109/JIOT.2023.3329456
[5] Florescu A. Digital twin for flexible manufacturing systems and optimization through simulation: a case study. Machines (Basel). 2024;12(11):785. doi: 10.3390/machines12110785
[6] Zhang K, Zhou H-Y, Baptista-Hon DT, et al. Concepts and applications of digital twins in healthcare and medicine. Patterns. 2024;5(8):101028. doi: 10.1016/j.patter.2024.101028
[7] Precedence Research. Digital twin market size, share, and trends analysis report by application, by industry, and segment forecasts, 2025–2034. Precedence Research; 2025.
[8] Jeremiah SR, El Azzaoui A, Xiong NN, et al. A comprehensive survey of digital twins: applications, technologies and security challenges. J Syst Archit. 2024;151:103120. doi: 10.1016/j.sysarc.2024.103120
[9] Soldatos J, Philpot J, Giunta G. Cyber-physical threat intelligence for critical infrastructures security: a guide to integrated cyber-physical protection of modern critical infrastructures. Now Publishers; 2020.

[10] Suhail S, Iqbal M, McLaughlin K. Digital-twin-driven deception platform: vision and way forward. IEEE Internet Comput. 2024;28(4):40–47. doi: 10.1109/MIC.2024.3406188
[11] Zanasi C, Russo S, Colajanni M. Flexible zero trust architecture for the cybersecurity of industrial IoT infrastructures. Ad Hoc Networks. 2024;156:103414. doi: 10.1016/j.adhoc.2024.103414
[12] Holland JH. Adaptation in natural and artificial systems: an introductory analysis with applications to biology, control, and artificial intelligence 2nd ed. MIT Press; 1992.
[13] National Institute of Standards and Technology. *Zero trust architecture*. NIST Special Publication 800-207. U.S. Department of Commerce; 2020. doi: 10.6028/NIST.SP.800-207
[14] Islam MK, Aslam U, Khan MZI, et al. Power system digital twins in action: what we learnt and where we go next. Digital Twins Appl. 2025;2(1):e70015. doi: 10.1049/dgt2.70015
[15] Ferdousi R, Laamarti F, Hossain MA, et al. Digital twins for well-being: an overview. Digital Twin. 2025; 2(3):2530296. doi: 10.12688/digitaltwin.17475.2
[16] Hasan S, Crawford C. A new era for digital twins: progress and industry adoption. 2025 doi: 10.20944/preprints202505.0784.v1
[17] Pronost G, Mayer F, Camargo M, et al. Digital twins along the product lifecycle: a systematic literature review of applications in manufacturing. Digital Twin. 2024;1(2):3. doi: 10.12688/digitaltwin.17807.2
[18] Iliu,ťa ME, Moisescu MA, Pop E, et al. Digital twin—a review of the evolution from concept to technology and its analytical perspectives on applications in various fields. Appl Sci. 2024;14(13):5454. doi: https://doi.org/10.3390/app14135454
[19] Bam PG, Rezaei N, Roubanis A, et al. Digital twin applications in the water sector: a review. Water (Basel). 2025;17(20):2957. doi: 10.3390/w17202957
[20] Wu B, Feng W, Wang T, et al. *Proceedings of the International Conference on Transportation Information and Safety (ICTIS)*. Review of techniques and challenges of digital twin applications in autonomous waterborne transportation. IEEE; 2025. p. 269–276. doi: 10.1109/ictis68762.2025.11214842
[21] Kitchenham B, Charters S. *Guidelines for performing systematic literature reviews in software engineering* (Technical Report EBSE 2007001). Keele University and Durham University; 2007.
[22] Page MJ, McKenzie JE, Bossuyt PM, et al. The PRISMA 2020 statement: an updated guideline for reporting systematic reviews. BMJ. 2021;372:n71. doi: 10.1136/bmj.n71
[23] Alahmadi AN, Rehman SU, Alhazmi HS, et al. Cyber-security threats and side-channel attacks for digital agriculture. Sensors. 2022;22(9):3520. doi: 10.3390/s22093520
[24] Atalay M, Angin P. A digital twins approach to smart grid security testing and standardization. 2020 IEEE International Workshop on Metrology for Industry 4.0 & IoT. IEEE; 2020. p. 1–6.
[25] Dietz M, Putz B, Pernul G. A distributed ledger approach to digital twin secure data sharing. In Foley SN, editor. Data and applications security and privacy XXXIII. Springer; 2019. p. 281–300.
[26] Garcia-Perez A, Cegarra-Navarro JG, Sallos MP, et al. Resilience in healthcare systems: cyber security and digital transformation. Technovation. 2023;121:102583. doi: 10.1016/j.technovation.2022.102583
[27] Idrisov IN, Okeke D, Albaseer A, et al. Leveraging digital twin and machine learning techniques for anomaly detection in power electronics dominated grid. arXiv Preprint arXiv:2501.13474. 2025.[Preprint, pending peer review].
[28] Jagannath J, Ramezanpour K, Jagannath A. *Proceedings of the 2022 ACM Workshop on Wireless Security and Machine Learning Association for Computing Machinery*. Digital twin virtualization with machine learning for IoT and beyond 5G networks: research directions for security and optimal control; 2022. p. 81–86. doi: 10.1145/3522783.3529519
[29] Sabatucci L, Augello A, Caggianese G, et al. Coordinating systems of digital twins with digital practices. European Conference on Multi-Agent Systems. Springer; 2023. p. 406–414. doi: 10.1007/978-3-031-43264-4_26
[30] Zhao T, Foo E, Tian H. A digital twin framework for cyber security in cyber-physical systems. arXiv Preprint arXiv:2204.13859. 2022.
[31] Li S, Cheng W, Liu Z, et al. Key technologies and applications of Digital Twin hydraulic engineering. Digital Twin. 2025;2(1):2486862. doi: 10.1080/27525783.2025.2486862